EXECUTIVE SUMMARY

Severity	Count	Key Risk
CRITICAL	8	Plaintext passwords · Forged JWTs · Billing portal hijack · Unauthenticated referral rewards
HIGH	20	XSS in 2 tools · SSRF in 3 endpoints · All PDF routes unauth · False redaction/protection
MEDIUM	27	Race conditions · Broken OG images · Dead sanitizer · Query logging in prod · No Suspense
LOW	17	Timing attacks · Math.random() for secrets · Conflicting next.config · Brand inconsistency

Critical combination: Findings C1 + C2 together mean plaintext passwords are stored while any attacker can forge JWTs using the known fallback secret — full database credential exposure with zero effort. These two must be fixed before anything else.

CRITICAL FINDINGS

#	Severity	Area	File	Issue
C1	CRITICAL	Frontend	`api/auth/register/route.ts:18`	Plaintext passwords stored in DB. Field named passwordHash stores raw string — no bcrypt/argon2 call.
C2	CRITICAL	API	`middleware/requireAuth.ts:19`	Hardcoded JWT fallback 'change-this-secret-in-production'. Any env where JWT_SECRET is unset allows forged JWTs for any user/admin.
C3	CRITICAL	Frontend	`middleware.ts:5-11`	Admin auth via plain cookie string compare (timing-unsafe). No server-side guard inside admin/analytics page.
C4	CRITICAL	API	`middleware/csrfProtection.ts:36`	CSRF bypass via any X-Api-Key header value — presence (not validity) skips CSRF on all state-mutating routes including /api/billing and /api/gdpr/delete.
C5	CRITICAL	API	`routes/billing.ts:64`	Attacker-supplied Stripe customerId accepted without ownership check. Any authenticated user can open billing portal for another user's payment methods.
C6	CRITICAL	API	`routes/referral.ts:44`	Unauthenticated referral apply endpoint. Caller supplies arbitrary newUserId — anyone claims rewards for any account.
C7	CRITICAL	API	`routes/api-keys.ts:52-53`	Race condition on API key cap. count() + create() not atomic — 10 concurrent requests bypass the 10-key limit.
C8	CRITICAL	Frontend	`api/auth/register/route.ts`	No rate limiting on registration — unlimited account creation; 409 response confirms email existence.

HIGH FINDINGS

#	Severity	Area	File	Issue
H1	HIGH	Frontend	`MarkdownEditorClient.tsx:18`	XSS via unsanitized Markdown. [click](javascript:alert(1)) renders as executable <a href> via dangerouslySetInnerHTML.
H2	HIGH	Frontend	`link-to-us/page.tsx:131`	XSS via user-controlled badge label — raw HTML template injected straight into dangerouslySetInnerHTML.
H3	HIGH	API	`routes/network.ts:55`	SSRF via /api/network/http-headers — no RFC-1918 blocklist; attacker can hit AWS metadata endpoint, Redis, internal Docker services.
H4	HIGH	API	`routes/network.ts:87`	SSRF/internal port scan via /api/network/port-checker — socket.connect(port, host) with only z.string().min(1) validation.
H5	HIGH	PDF	`All web PDF routes`	No file-type validation on web PDF endpoints — any binary accepted; renaming .exe to .docx feeds it into mammoth/xlsx parsers.
H6	HIGH	PDF	`api/pdf/merge/route.ts`	No file size limit + unlimited file count — memory exhaustion DoS; getAll('files') with no cap.
H7	HIGH	PDF	`api/pdf/unlock/route.ts:12`	Unauthenticated PDF decryption. ignoreEncryption:true strips any password with zero auth, zero rate limit, zero size limit.
H8	HIGH	PDF	`apps/api/src/index.ts:106`	Zero authentication on all 22 backend PDF operations — merge, compress, protect, sign, OCR all fully public.
H9	HIGH	PDF	`lib/gotenberg.ts:81-89`	SSRF via urlToPdf() — exported function passes user-controlled URL to Gotenberg Chromium with no blocklist.
H10	HIGH	PDF	`Multiple routes`	Content-Disposition header injection via unsanitized file.originalname — newlines in filename inject arbitrary HTTP headers.
H11	HIGH	PDF	`api/pdf/protect/route.ts:49`	False 'password protection' — password silently discarded; document saved unencrypted; response still says passwordProtected: true.
H12	HIGH	PDF	`api/pdf/redact/route.ts`	Redaction is cosmetic only — adds a footer stamp; original text fully readable. Redacted terms returned in response body.
H13	HIGH	API	`routes/url-shortener.ts:18`	Unauthenticated URL shortening + open redirect — no scheme validation; javascript: URLs accepted; SSRF via internal URLs.
H14	HIGH	API	`routes/url-shortener.ts:29-46`	Slug uniqueness bug — retry loop updates 'attempt' but DB insert always uses original 'slug'; collisions cause unhandled 500s.
H15	HIGH	API	`routes/affiliate.ts:78`	Any authenticated user can view any affiliate code's revenue stats — no ownership check on ?code= param.
H16	HIGH	Frontend	`api/api-keys/[id]/route.ts:10`	IDOR on API key deletion — no ownership check in Next.js layer before proxying to backend.
H17	HIGH	Frontend	`api/billing/checkout/route.ts`	No auth guard on checkout creation — no getServerSession() call; unauthenticated requests forwarded to billing backend.
H18	HIGH	Frontend	`api/auth/me/route.ts:6`	getServerSession() without authOptions always returns null. No [...nextauth]/route.ts exists — NextAuth not wired up; signIn() 404s in production.
H19	HIGH	SEO	`apps/web/src/app/security/`	Duplicate URL tree — /security/{tool} and /tools/security/{tool} both live; no canonicals; PageRank split.
H20	HIGH	SEO	`Sitemap files`	Broken sitemap URL mapping — sitemap-pdf.ts outputs /tools/pdf/ slugs while actual pages are at /tools/document-tools/.

MEDIUM FINDINGS

#	Severity	Area	File	Issue
M1	MEDIUM	API	middleware/sanitizer.ts	Sanitizer middleware never registered in index.ts — app.use(sanitizer) missing; all sanitization is dead code.
M2	MEDIUM	API	routes/billing.ts:99	Non-atomic webhook handler — subscription upsert + referral reward not in a transaction; Stripe retries can double-grant credits.
M3	MEDIUM	API	routes/billing.ts:84	Webhook bypass when STRIPE_WEBHOOK_SECRET unset — all webhook calls accepted without signature verification.
M4	MEDIUM	API	routes/referral.ts:22	Race condition on referral code creation — findUnique + create not atomic; concurrent requests crash with unique-constraint error.
M5	MEDIUM	API	routes/newsletter.ts:17	!email.includes('@') is not email validation — <script>@x.com passes; no length limit. Unauthenticated unsubscribe by email.
M6	MEDIUM	API	routes/calculators/mortgage.ts:27	Negative loan amount not validated — downPayment > homePrice produces negative monthly payment returned as valid.
M7	MEDIUM	API	routes/calculators/roi.ts:32	breakEvenYears returns NaN/Infinity on total-loss scenario (cagr = -100%).
M8	MEDIUM	API	utils/pagination.ts:36	sortBy from caller passed directly to Prisma orderBy — if wired to req.query, any column (inc. passwordHash) becomes sortable.
M9	MEDIUM	API	routes/url-shortener.ts:71	Wrong field name — req.user.id used but AuthPayload stores userId; list endpoint always returns empty array.
M10	MEDIUM	API	routes/tool-analytics.ts:24	Unauthenticated write; userId is caller-supplied — anyone can pollute analytics with fake data for any user ID.
M11	MEDIUM	API	routes/contact.ts:27	XSS in outbound email — message interpolated as HTML without escaping; <script> tags execute in support team's email client.
M12	MEDIUM	API	middleware/fileValidator.ts:267	Unrecognized binary types pass validation silently — if(!detected) skips MIME check in multi-file path.
M13	MEDIUM	API	middleware/fileValidator.ts:138	Per-tier size limit skipped for multi-file uploads — enforceFileSizeLimit checks req.file (undefined for arrays); free users can upload 4 GB via merge.
M14	MEDIUM	API	routes/pdf/sign.ts:76	Unbounded base64 signatureData body field — bypasses multer file size limits; multi-MB payloads accepted as JSON.
M15	MEDIUM	PDF	routes/pdf/*.ts	Raw err.message returned directly — bypasses errorHandler; leaks Gotenberg internal URLs, file paths, service names.
M16	MEDIUM	PDF	lib/gotenberg.ts:184	Gotenberg unreachable error includes internal Docker hostname verbatim in the HTTP response.
M17	MEDIUM	PDF	api/pdf/convert-from-pdf/route.ts:86	Zip bomb / decompression bomb — JSZip and pdfjs iterate crafted archives/pages with no decompressed-size limit.
M18	MEDIUM	Frontend	dashboard/page.tsx	Client-side-only auth redirect — HTML served to unauthenticated bots/crawlers before JS fires.
M19	MEDIUM	Frontend	lib/prisma.ts:10	log:['query'] in all environments — all SQL queries with user values logged to stdout in production.
M20	MEDIUM	Frontend	blog/[slug]/page.tsx:95	Blog content rendered via dangerouslySetInnerHTML without sanitization — XSS-ready if blog data ever comes from an API.
M21	MEDIUM	SEO	lib/seo.ts:36	OG images 404 for homepage, all category pages, and all 194 tool pages — every social share shows no preview image.

#	Severity	Area	File	Issue
M22	MEDIUM	SEO	app/robots.ts:34	sitemap-real-estate.xml listed in robots.txt but file does not exist — Google Search Console will report a failed sitemap.
M23	MEDIUM	Perf	app/layout.tsx:66	Second font loaded via raw <link> instead of next/font — blocks render, no font-display:swap, no preload hint.
M24	MEDIUM	Perf	tailwind.config.ts:6	3 Tailwind font families declared but never loaded — font-display/body/mono classes fall back to system fonts; design system broken.
M25	MEDIUM	Perf	app/layout.tsx	Zero <Suspense> boundaries across entire app (one usage in search only) — all tool pages block full RSC stream on slow data.
M26	MEDIUM	Perf	components/SiteHeader.tsx	Entire 430-line nav is a monolithic 'use client' component — static category data forces full JS bundle; not pre-renderable.
M27	MEDIUM	Perf	app/layout.tsx:103	<GoogleAnalytics> and <AdSenseScript> in <head> with no error boundary — either throwing crashes the entire site layout.

LOW FINDINGS

#	Severity	Area	File	Issue
L1	LOW	API	routes/auth.ts:33	Email enumeration via bcrypt timing difference; fix with dummy hash compare on missing users.
L2	LOW	API	routes/api-keys.ts:114	Admin key comparison uses === (not crypto.timingSafeEqual).
L3	LOW	API	routes/url-shortener.ts:89	Stats endpoint leaks userId and internal fields to anonymous callers.
L4	LOW	API	routes/url-shortener.ts:11	Math.random() used for slug generation; use crypto.randomBytes.
L5	LOW	API	routes/pdf/protect.ts:41	Owner password generated with Math.random(); use crypto.randomBytes.
L6	LOW	API	middleware/fileValidator.ts:167	VirusTotal fails open on all errors (timeout, quota, network failure).
L7	LOW	API	middleware/requireAuth.ts:47	7-day JWTs with no server-side revocation; stolen tokens valid for a week.
L8	LOW	API	index.ts:82	10 MB JSON body limit applied to all routes including auth and analytics.
L9	LOW	API	middleware/csrfProtection.ts:32	/api/v1/ CSRF exempt by prefix; future state-mutating routes silently unprotected.
L10	LOW	PDF	Universal	Universal ignoreEncryption:true silently strips owner permissions from every processed PDF.
L11	LOW	Frontend	next.config.ts:40	CSP contains 'unsafe-eval' + 'unsafe-inline'; provides no XSS mitigation.
L12	LOW	Frontend	next.config.js + next.config.ts	Two conflicting config files — .js takes priority; security headers, output:standalone, removeConsole silently disabled.
L13	LOW	Frontend	(auth)/signup/page.tsx:98	Terms checkbox not enforced server-side; direct API calls bypass ToS acceptance.
L14	LOW	SEO	Multiple files	Brand name inconsistency — 'Toolverse' in manifest/OG vs 'RoughTools' in header and site title.

#	Severity	Area	File	Issue
L15	LOW	SEO	`tools/[category]/[tool]/page.tsx:52`	Default FAQ states 'up to 20 uses/day' contradicting homepage 'no limits ever'.
L16	LOW	SEO	`All tool pages`	All 194 tool pages render a placeholder UI ('Tool interface coming in Phase 5') — thin content risk.
L17	LOW	SEO	`app/manifest.ts:79`	PWA shortcut links to /tools/pdf which resolves to a 404.

PRIORITY ACTION PLAN

Week 1 — Stop the Bleeding	
C1	Hash passwords: add bcrypt.hash(password, 12) in register/route.ts
C2	Remove JWT fallback secret; throw at startup if JWT_SECRET is unset
H11/H12	Remove false protect/redact endpoints or add hard warnings — they are security theater
H3/H4	Add RFC-1918 blocklist to all outbound fetch/socket calls in network.ts
C5	Remove customerId fallback from request body in billing portal endpoint
Sprint 1	
C4	Fix CSRF bypass: check req.user (set by auth), not raw header presence
C6	Add requireAuth to referral apply; derive newUserId from JWT token
H1/H2	Sanitize all dangerouslySetInnerHTML sites (DOMPurify or sanitize-html)
H5–H8	Add file type validation + size limits to all Next.js PDF routes
M21	Fix OG images: use Next.js opengraph-image.tsx or add actual static images
L12	Delete next.config.js; keep only next.config.ts
Sprint 2	
M1	Wire up app.use(sanitizer) in index.ts
M15	Wrap all PDF route errors with next(err) instead of raw res.json
M25	Add <Suspense> boundaries to tool pages
H19	Resolve duplicate /security/ URL tree with 301 redirects and canonical tags
H20	Fix broken sitemap paths — align all PDF tool URLs

Audit completed: May 30, 2026 | Scope: apps/web (Next.js 14) + apps/api (Express) | Audited by: Claude Code — 5 independent parallel analysis agents

This report is confidential and intended for internal development use only.